ENGINEERING BUILD REPORT

Identity Verification System

Insighta research marketplace — tiered verification & anti-fraud layer

Project	Insighta (FastAPI · Jinja2 · SQLAlchemy)
Branch	`feat/matching-and-tier-ux` (merged with origin/main, 66 upstream commits)
Repository	github.com/selinazwj/Insighta
Author	jai0812
Date	21 July 2026
Status	**Core complete · 24/24 regression tests passing · CI green**

---

1. Executive summary

Insighta now has a complete, production-shaped identity-verification layer. When publishing a study, a researcher can require participants to be verified at one of three strengths — and, for the basic tier, restrict participation to specific email domains (e.g. `bu.edu` for BU students only). Participants prove their identity through a dedicated `/verify` page offering four methods: an emailed one-time code, a domain-restricted email, LinkedIn sign-in, or a government-ID photo that the **researcher** reviews and approves.

The design holds one principle throughout: **verification is a signal to the researcher, not a wall in front of the participant.** The researcher funds and releases every payout, and now sees each participant's verification status — and reviews their uploaded ID — before approving. A three-part bot-defense layer (rate limiting, a math CAPTCHA, and a honeypot) protects the account and verification endpoints.

The work spans **24 focused feature commits**, was merged cleanly with 66 upstream commits from the rest of the team, and passes a full end-to-end regression across both survey types.

2. The problem

A research marketplace pays real money to participants, which creates two risks:

- **Fraud** — bots and duplicate accounts farming payouts.
- **Eligibility** — a study for licensed physicians, or for BU students only, needs a way to confirm those claims.

Before this work, anyone could register with an email and password and be paid for any study. There was no notion of *who this person really is*, and no way for a researcher to say "only verified nurses" or "only `@bu.edu` emails." The goal was a verification system that is **flexible** (researchers choose the strength per study), **self-serve** (participants verify themselves), and **non-blocking** (it never breaks the existing take-a-survey and researcher-approval flows, including the partner team's quality-review engine).

3. The three-tier model

A participant satisfies a study when their tier is at least as strong as required — and, for a Tier 3 study with a domain rule, their proven email matches.

TIER	STRENGTH	HOW THE PARTICIPANT PROVES IT	WHO APPROVES
Tier 1	Strongest	Uploads a government ID photo	The **researcher** reviews & approves
Tier 2	Standard	Signs in with LinkedIn (OAuth)	Automatic on OAuth success
Tier 3	Basic (default)	One-time code emailed to them — optionally domain-restricted	Automatic on correct code

> **Upgrades, never downgrades.** A Tier 3 participant can later verify via LinkedIn or ID to become Tier 2 / Tier 1. A weaker method never lowers a tier already earned — the system always keeps the strongest proof.

4. How it works — end to end

```
Researcher          Participant          Verify              Researcher          Payout
----------          -----------          ------              ----------          ------
publishes a study > completes it >       if tier is short,  > sees verification > funds
sets occupation,    response marked      sent to /verify to  badge + reviews     credited;
tier & domains      "under review"       prove the tier      ID on a dedicated   participant
                                                              page; approves      withdraws
```

- **Registration** asks the participant's occupation (a tier-grouped dropdown) as a step in signup.
- **Publishing** shows a "Verification requirements" section — required occupation(s), a required tier, and optional allowed email domains.
- **On completion**, if the participant's tier doesn't satisfy the study, they are redirected to `/verify` with a banner. The verify page shows **only the required tier's method**.
- **The researcher** sees a green/amber verification badge on each response in their notifications bell, plus a **dedicated ID-review page**, and decides whether to approve the payout.

5. What was built — phase by phase

Phase A — Schema foundation

Verification columns added to `User` and `Survey`, with migration scripts. Groundwork for everything else.

Phase B — Wiring onto the UI

Occupation step added to registration; "Verification requirements" section added to all three publish forms (external, in-person, edit); first `/verify` page with GET/POST routes.

Redesign — Gate moved to researcher approval

The gate was moved off the participant's withdrawal onto the **researcher's payout-approval** step, preserving the "researcher always releases payment" rule and coexisting with the partner team's quality-review engine.

Phase 2a — Email one-time code (Tier 3)

Real emailed six-digit code, reusing the platform's existing OTP infrastructure.

Phase 2b — LinkedIn OAuth (Tier 2)

"Verify with LinkedIn" reusing the existing OAuth flow. **Now live** with real LinkedIn app credentials configured via `.env`; degrades gracefully when not configured.

Phase 2c & 3 — ID upload + per-tier enforcement

ID-document upload (Tier 1) and tier-ranking logic comparing a participant's tier against each study's requirement everywhere it matters. ID files stored in a private, non-web-served folder.

Phase 4 — Bot defense

A self-contained module: in-memory rate limiting on all sensitive endpoints, an HMAC-signed math CAPTCHA on registration, and a hidden honeypot field. No external services required.

Participant nudge & domain-restricted email

Completion redirects an unqualified participant to `/verify` with a clear banner. Researchers can restrict Tier 3 to specific email domains, enforced **at verify time** — entering `abc.com` for a `bu.edu`-only study is rejected immediately, not silently at payout.

Occupation targeting enforced

`required_occupation` (now multi-select) filters who sees and can take a study — a lawyers-only study is hidden from students on the home feed.

Researcher ID review — dedicated page + email

The **researcher** who is paying reviews IDs (replacing the earlier admin-only queue). A dedicated page (`/researcher/id-reviews`) lists every participant who uploaded an ID for their gated studies, with View ID / Approve → Tier 1 / Ask to resend photo. On upload, every waiting researcher gets an **email notification** linking to the page.

UI polish

Skip button on the researcher guided tour; breathing room + larger text on the home-page stats; verification requirements restyled with an occupation **multiselect dropdown** and **big tier cards with hover tooltips**.

6. Full end-to-end regression test — 24/24 passed

Run against the merged code with real accounts (researcher, a lawyer participant, a student participant). Every step verified against the database, not just page loads.

Test A — External form (lawyer-only, Tier 1 ID required)

#	STEP	RESULT
A1	Researcher publishes external form (lawyer-only, Tier 1)	**PASS**
A2	Lawyer **sees** it on home feed	**PASS**
A3	Student does **not** see it (occupation targeting)	**PASS**
A4	Lawyer completes → verify nudge (needs tier_1)	**PASS**
A5	Bell notification created for the researcher	**PASS**
A6	Verify page shows **only ID upload** (tier-focused)	**PASS**
A7	ID upload → **pending**, not auto-approved	**PASS**
A8	Researcher's ID review page lists the participant + study	**PASS**
A9	Owner researcher can view the ID document	**PASS**
A10	Stranger blocked from the document (403)	**PASS**
A11	Approve → participant becomes **verified Tier 1**	**PASS**
A12	Bell badge flips to verified, warning gone	**PASS**
A13	Researcher accepts → payout released	**PASS**
A14	Completed study left Home, appears in My Studies	**PASS**

Test B — Built-in form (survey builder, Tier 3 + bu.edu domain rule)

#	STEP	RESULT
B1	Built-in draft created via the survey builder	**PASS**
B2	Published with **bu.edu** email restriction	**PASS**
B3	Participant sees it on home	**PASS**
B4	Take page opens	**PASS**
B5	Submit → quality engine scores it **and** verify nudge fires	**PASS**
B6	`abc.com` email **rejected** at send-code	**PASS**
B7	`bu.edu` email accepted, OTP issued	**PASS**
B8	OTP verified → email recorded, **Tier 1 not downgraded**	**PASS**
B9	Bell shows domain satisfied, no warning	**PASS**
B10	Payout accepted	**PASS**

> **Result: 24 / 24 passed.** All test data reverted afterward. The quality engine and verification nudge coexist cleanly in the same response (B5).

7. Security & anti-fraud notes

- **ID documents are never web-accessible.** Stored in `uploads/id_documents/` (git-ignored, outside `app/static`). The only way to view one is `GET /researcher/id-document/{id}`, scoped so a researcher only opens IDs of participants who responded to *their own* gated studies; anyone else gets 403. The route refuses any path outside the documents folder.
- **Domain rules enforced server-side twice** — when sending the code and on final submit — so a crafted request can't bypass the restriction.
- **OTP brute-force capped** at five attempts per user per ten minutes.
- **Stateless CAPTCHA** — the answer is never sent to the browser; the token is an HMAC of the answer, verified with a constant-time compare.
- **Private pages carry** `noindex, nofollow` via the shared SEO partial, so verification/account pages can never enter a search index.

> **Honest limitation:** ID review is currently a **human** decision (the researcher looks at the photo). There is no automated OCR or face-match yet — that is intentional for this phase and is future work.

8. Continuous integration

The team's `SEO checks` GitHub Actions workflow runs on every push: (1) `seo_audit.py --strict` audits every template for SEO hygiene and enforces `noindex` on private pages; (2) `smoke_test_seo.py` runs route smoke tests. The verification templates were brought into compliance (they include the shared `_seo_head.html` partial). **`seo_audit --strict` passes 59/59.**

9. Reference tables

9.1 Database columns added

TABLE	COLUMN	PURPOSE
users	`occupation`	Self-declared occupation (tier-grouped)
users	`verification_status`	unverified / verified
users	`verified_tier`	tier_1 / tier_2 / tier_3
users	`verified_at`	Timestamp of verification
users	`verified_email`	Email proven via OTP (may differ from account email)
users	`id_document_path`	Private path to the uploaded ID file
users	`id_review_status`	pending / approved / rejected
users	`id_uploaded_at`	When the ID was uploaded
surveys	`required_occupation`	Comma-separated occupations that may take the study
surveys	`required_verification_tier`	Minimum tier to be paid (default tier_3)
surveys	`required_email_domains`	Comma-separated allowed domains (e.g. bu.edu,gmail.com)

9.2 Key endpoints (new or changed)

ROUTE	METHOD	ROLE	PURPOSE
`/register`	GET·POST	Participant	Occupation step; CAPTCHA + honeypot on POST
`/verify`	GET·POST	Participant	Verify page; OTP submit with domain check
`/verify/send-code`	POST	Participant	Emails an OTP to a chosen address
`/verify/id-upload`	POST	Participant	Stores ID → pending; emails researchers
`/verify/linkedin`	GET	Participant	Starts LinkedIn OAuth (Tier 2)
`/researcher/id-reviews`	GET	Researcher	Dedicated ID review page
`/researcher/id-document/{id}`	GET	Researcher	View one ID (scoped, private)
`/researcher/id-reviews/{id}/approve`	POST	Researcher	Grant Tier 1
`/researcher/id-reviews/{id}/reject`	POST	Researcher	Ask for a new photo
`/api/notifications`	GET	Researcher	Adds verification badge + ID-review fields
`/publish` · `/publish_interview`	POST	Researcher	Capture occupation / tier / domains
`/surveys/{id}/complete` · `/submit`	POST	Participant	Return "needs verification" for the nudge

9.3 New files & migrations

FILE	PURPOSE
`app/bot_defense.py`	Rate limiting, CAPTCHA, honeypot helpers
`app/templates/verify.html`	Participant verification page (4 methods)
`app/templates/researcher_id_reviews.html`	Researcher ID review page
`migrate_verification.py`	Phase A columns
`migrate_sync_schema.py`	Schema-drift sync
`migrate_id_document.py`	`id_document_path`
`migrate_email_domains.py`	`verified_email`, `required_email_domains`
`migrate_id_review.py`	`id_review_status`, `id_uploaded_at`

9.4 Commit history (feature work, newest first)

COMMIT	SUMMARY
`2a75746`	Include shared SEO partial in verification templates (CI green)
`f45a08e`	Dedicated researcher ID review page + email alert on upload
`372502f`	Dedupe completion-notify logic, batch notification queries
`0e5b36c`	Clean post-verify success screen + in-person ID-required toggle

COMMIT	SUMMARY
`b55dcc7`	Researcher reviews participant IDs from the bell (admin queue removed)
`accf67e`	Enforce occupation targeting + create bell notifications on completion
`5e0008f`	Restyle verification requirements — occupation dropdown + tier cards
`95bf479`	Completed studies leave home, tier-focused verify, multi-occupation
`dc40025`	Replace ID auto-approve with a review queue
`fabe79f`	Skip button on researcher tour + home-stats spacing
`09a8e6d`	Enforce required email domains at verify time
`0b3c8a0`	Domain-restricted email verification + verify-page logo
`9ee0e8d`	Gate survey completion on participant verification tier
`c285309`	Bot defense (Phase 4) — rate limits, CAPTCHA, honeypot
`bd43d03`	ID upload (2c) + per-tier enforcement (3)
`a435e31`	LinkedIn OAuth verification (2b)
`e63c1b6`	Move verification gate to researcher payout approval
`cfce8cb`	Email OTP verification flow (2a)
`fd5f3b6`	Verification gate on withdrawal (later superseded)
`8149bce`	Verification settings on publish forms
`2287014`	`/verify` route and template
`bc876f9`	Occupation step on registration
`7d72905`	Verification columns on User & Survey (Phase A)

10. What's left — roadmap

Everything below is intentionally deferred; nothing here blocks the current feature.

ITEM	WHAT IT MEANS	PRIORITY
Automated ID checks	OCR / face-match so ID review isn't fully manual	Later
Real credential lookups	NPI registry (physicians), bar directory (lawyers), auto .edu detection	Later
Rate limits → Redis	Limits are in-memory (reset on restart, single-worker); move to Redis for multi-worker production	Pre-scale
Remove orphaned module	An older, unused `app/verification/` package predates this design	Low
Run prod migrations	The five `migrate_*.py` scripts must run against the production DB before deploy	At deploy

11. How to run & test

```
# Start the app
$env:DATABASE_URL="sqlite:///./survey.db"
python -m uvicorn api.main:app --port 8000

# Helper scripts (project root)
python _get_otp.py        # print the latest emailed OTP (local dev)
python _reset_user.py 2   # reset a user to unverified for re-testing

# LinkedIn (Tier 2) needs credentials in a .env file:
#   LINKEDIN_CLIENT_ID=...
#   LINKEDIN_CLIENT_SECRET=...
#   BASE_URL=http://127.0.0.1:8000
```

Researcher ID review page: `http://127.0.0.1:8000/researcher/id-reviews` (logged in as the study's researcher).

Report generated 21 July 2026. All work authored on Insighta's existing FastAPI + Jinja2 + SQLAlchemy stack and design system, and merged with the team's concurrent work on main.